

GUIDE DE CONFIGURATION CORS

Projet Federe (Healthcare App)

Date: 17 Fevrier 2026

Objet: Standardisation de la securite Cross-Origin

1. RESUME EXECUTIF

Cette application utilise une architecture frontend/backend separee :

- Backend: Spring Boot (Java 21) - Port 7070
- Frontend: React + TypeScript + Vite - Port 5173

La configuration CORS autorise la communication entre ces services avec des mesures de securite incluant JWT, OTP, et token blacklisting.

2. CONFIGURATION BACKEND (SPRING BOOT)

2.1 Parametres principaux (SecurityConfig.java)

- Origines autorisees: http://localhost:5173 (Vite), 3000 (CRA), 4200 (Angular)
- Methodes: GET, POST, PUT, DELETE, PATCH, OPTIONS
- En-tetes: '*' (Autorise Authorization, Content-Type, etc.)
- Allow Credentials: true (Obligatoire pour JWT/Cookies)

2.2 Securite Spring

- CSRF: Desactive (Utilisation de JWT).
- Session: STATELESS.
- Filtre: JwtAuthenticationFilter place avant UsernamePasswordAuthenticationFilter.

3. CONFIGURATION DES PROPERTIES

```
server.port=7070
app.jwt.secret=YXBwX21lZGljYWxIX3NlY3Jld...
app.jwt.expiration-ms=86400000 (24h)
app.otp.expiration-minutes=10
app.frontend.url=http://localhost:5173
```

4. CONFIGURATION FRONTEND (REACT)

Le frontend communique directement avec le backend via l'URL de base : http://localhost:7070/api.

```
// Exemple d'appel avec JWT
const response = await fetch(URL, {
  headers: {
    'Authorization': `Bearer ${token}`,
    'Content-Type': 'application/json'
  },
  credentials: 'include'
});
```

5. DEPANNAGE CORS

1. No 'Access-Control-Allow-Origin': Verifier les allowedOrigins dans le backend.
2. Method not allowed: Verifier que la methode HTTP est listee.
3. Preflight fails: Verifier que les requetes OPTIONS sont autorisees sans authentication.

6. CHECKLIST POUR FUTURS PROJETS

- ☐ Ne jamais utiliser '*' en production avec allowCredentials=true.
- ☐ Utiliser des variables d'environnement pour les secrets JWT.
- ☐ Activer HTTPS obligatoirement.
- ☐ Configurer les Security Headers (CSP, X-Frame-Options).
- ☐ Implementer un Refresh Token pour les sessions longues.